

ARGOS

Adaptive Response Guard with Orchestrated Surveillance
Sprint Semana 1 · Manual del integrante

Angeles Castillo

P3 · Detection & Deception

Tópicos Avanzados de Ciberseguridad · Universidad de Lima · 2026-1
Entrega final: 13 de junio de 2026
Generado: 2026-05-24

Parte I — Introducción al proyecto

ARGOS — Introducción al proyecto y arquitectura

Documento común a todos los manuales de integrante. Contiene contexto que cada miembro del equipo (P1/P2/P3/P4) necesita antes de leer su manual individual.

Field	Value
Type	Manual de introducción común para los 4 integrantes
Status	Active
Última actualización	2026-05-24
Pre-requisito	Ninguno. Léelo de cero.

1. Qué es ARGOS en una página

ARGOS es la **Adaptive Response Guard with Orchestrated Surveillance** — una plataforma multi-vector de detección y respuesta a amenazas que replica la arquitectura de productos comerciales high-end EDR/XDR (Microsoft Defender XDR, CrowdStrike Falcon, Palo Alto Cortex XDR) usando exclusivamente componentes open source más una API LLM de bajo costo para la capa de triage.

El proyecto es para el curso **Tópicos Avanzados de Ciberseguridad** en la Universidad de Lima · 2026-1. La entrega final es el **13 de junio de 2026** y consta de tres deliverables obligatorios: informe técnico (~30% del peso), demo en vivo (~40%) y presentación (~20%) más los seguimientos en semanas 5/7/9 (~10%).

El activo defendido es una base de datos **PostgreSQL 15** corriendo sobre una Linux VM en el lab. Tiene esquema `argos_demo_prod` con tablas que simulan datos de RRHH y finanzas (employees, payroll, customers, invoices, payments) con datos sintéticos. El host está tagged en Wazuh como `criticality=production-critical`, lo que dispara la regla de dos personas (two-person rule) para cualquier acción de containment sobre él.

El alcance multi-vector (post ADR-0008) cubre tres categorías de ataques distintas:

- **Ransomware:** cifrado de archivos via técnicas T1486/T1490/T1083/T1562. Es el énfasis primario.
- **Network Denial of Service:** ataques de red contra el puerto del servicio (T1498/T1499) con `hping3` o `slowhttptest`.
- **Application Abuse:** SQL injection contra una app web delante de la DB (T1190) usando `sqlmap`, y false positives de actividad legítima de usuario (T1078 Valid Accounts) — un SELECT masivo a las 3 AM se parece a exfiltración pero puede ser un reporte mensual legítimo.

Por qué este alcance y no más: ARGOS no busca cobertura exhaustiva multi-vector. Busca cobertura mínima representativa que demuestre que la arquitectura de 4 capas + SOAR + HITL

es genuinamente adaptativa. Cubrir 3 vectores con profundidad real es más defendible que cubrir 10 superficialmente.

2. Arquitectura de 4 capas defensivas

ARGOS sigue el patrón industrial estándar de **defense-in-depth**: cuatro capas independientes y paralelas, cada una con trade-offs distintos, fallan independientemente. Si una capa cae o es evadida, las otras tres mantienen cobertura. No hay un solo punto de falla en la detección.



Capa 1 — Rule-Based Detection (Sigma + Wazuh)

Dueño: P3 (Angeles). Reglas YAML escritas en formato Sigma, convertidas a Wazuh con `sigma-cli`, mapeadas explícitamente a técnicas MITRE ATT&CK. Detectan patrones conocidos.

Sub-categorías por dominio (post ADR-0008):

- `detection/sigma-rules/ransomware/` — vssadmin, T1486 cifrado, T1083 enumeración, T1562 disable defender, T1021 lateral, T1071 C2
- `detection/sigma-rules/network/` — rate-based rules para T1498/T1499 (DDoS, slow-rate)
- `detection/sigma-rules/database/` — query pattern anomalies para UC-07
- `detection/sigma-rules/webapp/` — T1190 SQL injection signatures

Trade-off honesto: alta precisión, recall limitado contra variantes nuevas. Por eso existe Capa 2.

Capa 2 — ML Anomaly Detection

Dueño: P2 (Sebastian). Modelos no supervisados entrenados sobre baseline benigno. Detectan desviaciones que las reglas no captan.

Modelos especializados por dominio (post ADR-0008):

- `ml/models/ransomware_ensemble.pkl` — Isolation Forest + One-Class SVM. Features ventana 60s: `file_write_rate`, `avg_entropy` (Shannon), `extension_modification_ratio`, `crypto_api_calls`, `new_outbound_connections`, `cpu_burst_score`, `io_burst_score`.
- `ml/models/network_traffic_anomaly.pkl` — para UC-06 DDoS. Features: `connections/sec`, `packet rate`, `source IP entropy`, `packet size variance`.
- `ml/models/query_pattern_anomaly.pkl` — para UC-07 SELECT masivo. Features: `rows_returned`, `query_duration_ms`, `hour_of_day`, `user_id`, `query_template_hash`.

Ensemble ransomware: `ensemble_score = 0.6 × isolation_forest_score + 0.4 × one_class_svm_score`. Los demás modelos retornan score único.

Trade-off honesto: mayor recall contra variantes nuevas, mayor false positive rate. Requiere baseline limpio.

Capa 3 — Canary Deception

Dueño: P3 (Angeles). Archivos-cebo (`financials_Q4_2025.xlsx` , `passwords.txt` , `db_backup.sql`) en ubicaciones donde un usuario legítimo nunca tocaría. FIM (File Integrity Monitoring) con Sysmon whodata (Windows) o auditd (Linux) captura QUÉ proceso accedió.

Lógica: primera modificación / lectura / rename de un canary = alerta crítica con confianza máxima. Por diseño, FP rate ≈ 0 .

Esta capa es estrictamente ransomware-specific. No tiene sub-categorías por dominio. Documentado deliberadamente en ADR-0008: defender contra DDoS o SQL injection requiere otras primitivas, no canaries.

Capa 4 — LLM-Assisted Triage

Dueño: P1 (Enzo). FastAPI service que recibe el contexto completo de una alerta (process tree, network connections, file modifications) y produce análisis estructurado: técnica MITRE, severidad, runbook NIST aplicable, acción recomendada, IoCs a correlar.

Backend vendor-agnostic (per ADR-0001 v2):

- **Primary:** OpenAI GPT-4o-mini (US-based, soberanía de datos aceptable)
- **Fallback:** Llama 3.1 8B local vía Ollama (zero-egress, funciona sin internet)

Invariante crítico R-02: el LLM **NUNCA** está en el **path crítico de containment**. El SOAR decide desde Capas 1-3 solamente. El LLM enriquece la vista del analista; si halucina, miente, o cae, el sistema sigue funcionando.

Pipeline RAG: BM25 (léxico) + BGE-large embeddings (denso) + RRF (Reciprocal Rank Fusion). Hybrid retrieval estándar industrial. Sin cross-encoder reranker (descartado en ADR-0001 v2 por marginal gain vs costo).

3. SOAR Decision Engine y los 4 tiers de confianza

El **SOAR (Security Orchestration, Automation and Response)** es el cerebro que fusiona señales de las 4 capas y decide la acción. Lo dueño es **P1**. Implementa la lógica de tiers per ADR-0003.

Tier	Disparado por	Confianza	Acción
☐ T0	Canary solo, OR las 3 capas corroboran	≥ 0.95	Aislamiento automático inmediato + snapshot
☐ T1	Layer 1 + Layer 2 corroboran (sin canary)	0.80–0.95	Aislamiento automático inmediato + snapshot
☐ T2	Capa sola con score alto	0.60–0.80	Throttle + snapshot ahora , aislamiento full pendiente de aprobación 3-min
☐ T3	Corroboración baja	0.40–0.60	Solo notificación enriquecida con LLM

(*) **Los thresholds son preliminares** pendientes de calibración empírica per `OPEN_QUESTIONS_RESOLUTION.md §Q5`.

Tier T2 — el más interesante

Ransomware moderno cifra ~25,000 archivos/min. Un countdown de 3 minutos para aprobación humana sin protección parece estúpido. Por eso T2 NO es "pendiente": es "throttle + snapshot AHORA, full isolation pendiente de aprobación". El throttle (cpulimit/ionice) reduce la tasa de cifrado a ~100-500 files/min mientras los aprobadores ven el contexto LLM y deciden. Si el timeout de 3 min expira sin respuesta, el sistema auto-ejecuta (no espera más). Si el aprobador clickea Reject, el throttle se levanta y el caso queda registrado como false positive con razón documentada — esto es UC-07.

Split-brain (conflicto multi-aprobador)

Per ADR-0006: cuando hay 4 aprobadores y dan respuestas contradictorias (2 approve, 1 reject, 1 timeout), se aplica **conservative-wins policy** con ventana de consolidación de 60 segundos: cualquier "approve" gana sobre rechazos, excepto para acciones irreversibles que requieren **two-person rule** (dos approves explícitos, un reject cancela).

El **two-person rule** se activa cuando el host afectado tiene `criticality=production-critical` (nuestro PostgreSQL). Esto es UC-04 en el demo.

Canales de notificación (per ADR-0007 v2)

Tiempo	Canal	Propósito
t=0	Telegram bot con botones inline JWT	Primario — push agresivo a celulares de aprobadores
t=0	Discord webhook con @-mention de role	Visibilidad en server del equipo, presión social
t=60s	Twilio Voice DTMF (sin STT)	Escalación si nadie respondió. "Presione 1 para aprobar, 2 para rechazar"
post-decisión	Email	Resumen asíncrono, NUNCA en path crítico

4. Equipo y responsabilidades

	Integrante	Rol	Alcance principal
☐	Enzo Ordoñez Flores	P1 · Líder · LLM/ SOAR	argos_contracts (entregado), Capa 4 LLM Triage, motor SOAR + Tier Classifier, Approval API con JWT, notificaciones multi-canal, Consola de Aprobación Streamlit, simulador de ransomware, playbooks de containment, coordinación
☐	Sebastian Montenegro	P2 · Ingeniero ML	Capa 2 completa (Isolation Forest + One-Class SVM ensemble + modelos especializados), feature extraction, calibración thresholds, métricas P/R/F1, captura forense
☐	Angeles Castillo	P3 · Detección y Engaño	Capa 1 (Sigma rules ransomware + network + database + webapp), Capa 3 (canary FIM + whodata), validación con Atomic Red Team y Caldera, bonus: PRs upstream a SigmaHQ
☐	Diego Jara	P4 · Infraestructura	Vagrantfile + Wazuh/OpenSearch/Redis deployment, PostgreSQL con datos sintéticos, simuladores (ransomware + DDoS + SQL injection), UI Streamlit base, video demo

Regla operativa crítica: cada integrante debe poder defender su capa en exposición. P1 no escribe código de otros con Claude Code. Cada integrante puede usar Claude Code (o cualquier asistente IA) como **acelerador en SU propia parte**, siempre que entienda lo que produce y pueda defenderlo en viva (per CONTEXT.md §5 reinterpretado post ADR-0008).

5. Los 8 use cases del demo

El demo en vivo cubre 8 escenarios (per ADR-0008 multi-vector). Cada UC tiene narrativa específica que demuestra una propiedad distinta del sistema.

UC	Vector	Tier	Capas que firing	Qué demuestra
UC-01	Ransomware (LockBit-like)	T0	1+2+3	Full-stack end-to-end. Las 3 capas firing simultáneo. Auto-isolate + email post-facto.
UC-02	Canary deception	T0	3 sola	Detección ultra-temprana. Zero archivos reales cifrados.
 UC-03	Variante novel + split-brain	T2	2 sola	Centerpiece HITL ransomware. ML atrapa lo que reglas no. 4 aprobadores. Conservative-wins live.
UC-04	PostgreSQL + two-person rule	T1	1+2	Compliance vocabulary. Four-eyes principle. Governance.
UC-05	Stealth attack (agent-kill)	T0	1+3+heartbeat	Resiliencia: agent disconnect = signal.
UC-06	DDoS volumetric	T0	1 (rate)+2 (network)	Cobertura multi-vector. Defiende contra ataques de red, no solo endpoint. T1498.
 UC-07	SELECT masivo legítimo FP	T2	2 sola	Pieza clave del HITL. Humano cancela contención por FP reconocido. T1078.
UC-08	SQL injection	T1	1+2	OWASP Top 10 #1. T1190 Exploit Public-Facing Application.

Los dos  son los UCs que más venden el HITL. UC-03 muestra split-brain con conservative-wins; UC-07 muestra cancelación de FP por humano. Ambos son lo que diferencia un EDR/XDR con HITL de un SIEM tradicional.

6. Ejemplo end-to-end de UC-01 paso a paso

Para que tengas un modelo mental concreto de cómo fluye una alerta a través del sistema, aquí está UC-01 (ransomware clásico LockBit-like) desglosado segundo a segundo.

Setup pre-ataque (T-5 min)

- Lab está corriendo: Wazuh manager + Windows VM + Linux VM con PostgreSQL.
- Los 4 aprobadores tienen Telegram abierto en sus celulares.
- La pantalla del proyector muestra: Streamlit Approval Console (vacía) + terminal de P4 listo para ejecutar el simulador.
- P1 narra el contexto: "Este es nuestro endpoint Windows típico de la organización. Tiene documentos en `C:\Users\Demo\Documents\`. El atacante acaba de obtener acceso inicial."

T=0 — Atacante ejecuta

P4 corre:

```
python attack-simulation/ransomware_simulator/lockbit_like.py --target windows-victim --speed full
```

Esto inicia el simulador. Behavior chain:

1. T+1s: enumera archivos en `C:\Users\Demo\Documents\` (técnica T1083 File and Directory Discovery)
2. T+2s: invoca `vssadmin delete shadows /all /quiet` (técnica T1490 Inhibit System Recovery)
3. T+3s: comienza a cifrar archivos con AES-256, renombrando a `.locked` (técnica T1486 Data Encrypted for Impact)
4. T+4s: toca el canary file `financials_Q4_2025.xlsx`
5. T+5s: deja la ransom note `README_RESTORE_FILES.txt` en el desktop

T+1 a T+5 segundos — Capas detectan en paralelo

Capa 1 (Sigma + Wazuh) detecta:

- T+2s: regla `T1490_vssadmin_delete_shadows` dispara cuando ve el comando `vssadmin`.
- T+3s: regla `T1486_mass_file_encryption_extension` dispara al ver renames masivos a `.locked`.
- Wazuh manager normaliza estas alertas y las publica al stream Redis `wazuh:alerts`.

Capa 2 (ML) detecta:

- ML consumer (Python proceso corriendo en bg) lee el stream Redis.
- Cada 60s genera features para los procesos activos. La ventana T+1 a T+60 captura el simulator process.
- Features observadas: `file_write_rate=347` archivos/min, `avg_entropy=7.8` (alta), `extension_modification_ratio=0.95`, `crypto_api_calls=42`, `cpu_burst_score=0.9`.
- Isolation Forest score: 0.94. One-Class SVM score: 0.91. Ensemble: 0.93.
- Publica `MLScore` con score 0.93 al stream Redis `ml:scores`.

Capa 3 (Canary FIM) detecta:

- T+4s: el simulator toca `financials_Q4_2025.xlsx`.
- Sysmon whodata captura el evento con PID del simulator y command-line completo.
- Wazuh dispara regla custom `canary_file_accessed` con severity 12 (crítica).
- Score implícito: 1.0 (canary fire = certeza máxima).

T+5 segundos — SOAR Decision Engine fusiona

El **SOAR orchestrator** (proceso de P1 corriendo el FastAPI Approval API en port 8003) se entera de las 3 alertas dentro del mismo incident window de 5 segundos.

Tier Classifier (`soar/decision_engine/tier_classifier.py`) aplica reglas:

- `canary_fired=True` → tier T0 (canary alone wins to T0).
- Pero también L1 + L2 corroboran con high scores → tier T0 confirmed.
- **Decisión:** `Tier.T0` con confidence 0.95+.

State machine (`soar/decision_engine/state_machine.py`):

1. Crea Incident con `incident_id=INC-2026-05-26-001`, state `RECEIVED`.
2. Persiste en Redis con key `incident:INC-2026-05-26-001`.
3. Llama al LLM Triage en paralelo (Capa 4 enrichment-only, NO bloquea decisión).

4. Transición de estado: `RECEIVED` → `PENDING_EXECUTION`.

Capa 4 LLM Triage (en paralelo, T+5 a T+8s):

- FastAPI `/triage` endpoint recibe el `AlertContext` con las 3 alertas.
- Llama a OpenAI GPT-4o-mini con prompt enriquecido.
- Devuelve `TriageResponse`: `tecnica_mitre=T1486`, `confianza=0.94`, `severidad=critical`, `runbook_aplicable="NIST 800-61 §3.4 Containment"`, `accion_recomendada="Isolate host immediately and capture memory snapshot before remediation"`.
- El Incident se actualiza en Redis con el `llm_analysis` campo.

T+8 segundos — Playbook automático

Como es T0 sin override de criticality (es una Windows VM standard, no production-critical), no requiere approval. El SOAR ejecuta el playbook directamente:

1. **Host isolation** (`soar/playbooks/host_isolation.py`): conecta vía PowerShell al Windows VM y crea regla firewall: `New-NetFirewallRule -DisplayName "ARGOS-Isolation" -Direction Outbound -Action Block`.
2. **Process kill**: identifica el PID del simulator desde el whodata FIM, ejecuta `Stop-Process -Force -Id <PID>`.
3. **Disk snapshot**: invoca Volume Shadow Copy `vssadmin create shadow /for=C:` para preservar evidencia forense.
4. Transición de estado: `PENDING_EXECUTION` → `EXECUTED`.

T+10 segundos — Notificación post-facto

El SOAR envía notificación multi-canal (per ADR-0007 v2):

- **Telegram** a los 4 `chat_ids` configurados: mensaje con `incident_id`, técnica, análisis LLM, y botón inline "Revertir" firmado con JWT.
- **Discord** webhook al server del equipo con embed coloreado por tier (T0 = rojo) y `@argos-approvers` mention.
- **Email post-facto** a `APPROVER_EMAILS` (los 4 emails del equipo) con resumen + link al audit log en OpenSearch.

T+10 a T+30 segundos — Streamlit Console muestra

La **Streamlit Approval Console** (proceso de P1 corriendo en port 8501, proyectado en pantalla) refresca cada 2 segundos vía `streamlit-autorefresh`. Muestra:

- **Panel izquierdo (Incident Card)**: badge T0 en rojo, `incident_id`, host afectado, técnica MITRE T1486, análisis LLM compacto.
- **Panel central (Decision Matrix)**: vacío porque es T0 auto-execute, no requirió aprobación.
- **Panel derecho (System Logic)**: estado actual `EXECUTED`, decisión `EXECUTE_ISOLATION`, política aplicada `auto-execute`, justificación "T0 confirmed: canary + L1 + L2 corroborate".
- **Panel inferior (Action Timeline)**: línea de tiempo horizontal mostrando: `alert created` → `tier classified` → `playbook executed` → `notifications sent`.

T+30 segundos — Análisis forense visible

P1 narra: "El sistema aisló el host en menos de 10 segundos. 31 archivos cifrados de 500. El canary salvó los restantes. Los 4 aprobadores tienen el incidente en su Telegram con la opción de Revertir si fuera falso. Audit log completo en OpenSearch con cada decisión justificada."

Métricas que se muestran en pantalla

- **TTD (Time to Detect):** 4.2 segundos desde T=0 hasta primera alerta válida.
- **TTI (Time to Isolate):** 8.7 segundos desde T=0 hasta playbook completado.
- **Archivos cifrados antes de containment:** 31 de 500 (94% preservados).
- **MITRE coverage:** T1083 + T1490 + T1486 cubiertos por L1, ratificados por L2 entropy spike, confirmados por canary L3.

Lo que NO se ve pero pasó

- LLM Triage tardó ~3 segundos en responder. NUNCA bloqueó la decisión de containment.
- El throttle preventivo NO se aplicó porque fue T0 (auto-execute directo). En T2 sí se habría aplicado mientras corre el countdown.
- El audit log en OpenSearch capturó: triggering layers, scores individuales, fusion logic, LLM analysis, playbook commands executed, notification channels disparados, timestamps de cada paso.

7. Glosario MITRE ATT&CK

Las técnicas relevantes al alcance del proyecto, ordenadas por categoría (tactic).

Initial Access

- **T1078 — Valid Accounts:** atacante usa credenciales legítimas. Relevante para UC-07 (escenario FP: usuario legítimo, NO atacante).
- **T1190 — Exploit Public-Facing Application:** explotación de vulnerabilidad en aplicación web expuesta. T1190.001 sub-técnica = SQL Injection. Relevante para UC-08.

Defense Evasion

- **T1562 — Impair Defenses:** atacante deshabilita herramientas de seguridad. T1562.001 sub-técnica = Disable Defender. Relevante para UC-05 (agent-kill attempt).
- **T1070 — Indicator Removal:** atacante borra rastros. T1070.001 = Clear Windows Event Logs, T1070.004 = File Deletion.

Discovery

- **T1083 — File and Directory Discovery:** ransomware enumera archivos antes de cifrar. Relevante para UC-01.

Lateral Movement

- **T1021 — Remote Services:** SMB/RDP/SSH usados por atacante para moverse. T1021.001 = RDP, T1021.002 = SMB, T1021.004 = SSH.

Command and Control

- **T1071 — Application Layer Protocol:** beacon a C2 server vía HTTP/HTTPS. T1071.001 sub-técnica = Web Protocols.

Impact (la más rica para ARGOS)

- **T1486 — Data Encrypted for Impact:** ransomware cifrando archivos. Núcleo de UC-01, UC-02, UC-03.
 - **T1490 — Inhibit System Recovery:** borrar Volume Shadow Copies, snapshots btrfs, etc. Pre-cursor a T1486.
 - **T1498 — Network Denial of Service:** ataques de red contra disponibilidad. T1498.001 = Direct Network Flood (UC-06), T1498.002 = Reflection Amplification.
 - **T1499 — Endpoint Denial of Service:** saturación de recursos del endpoint. T1499.002 = Service Exhaustion, T1499.004 = Application Exploitation.
-

8. Stack tecnológico completo

Categoría	Componente	Función	Owner principal
SIEM	Wazuh 4.7	Manager + agentes	P4
SIEM	OpenSearch	Storage de alertas y audit log	P4
SIEM	Sigma + sigma-cli	Reglas de detección	P3
Telemetría	Sysmon (Windows)	Eventos detallados de proceso/ archivo/red	P4
Telemetría	auditd (Linux)	Eventos detallados de syscall	P4
Telemetría	pgAudit (PostgreSQL)	Audit log de queries	P4
Telemetría	Wazuh FIM whodata	Captura qué proceso tocó archivo (canary)	P3
Simulación	Atomic Red Team	TTPs MITRE 1-a-1	P3
Simulación	Caldera	Cadenas de ataque multi-step	P3
Simulación	Custom ransomware simulator (Python)	UC-01, UC-02, UC-03 reproducibles	P1
Simulación	hping3 + slowhttptest	UC-06 DDoS	P4
Simulación	sqlmap	UC-08 SQL injection	P4
ML	scikit-learn 1.4+	Isolation Forest + One-Class SVM	P2
ML	scipy	Shannon entropy	P2
ML	pandas + numpy	Data wrangling	P2
ML	joblib	Model serialization	P2
Backend	FastAPI	LLM Triage API + Approval API	P1
Backend	Redis 7+	Alert bus + incident state machine	P4 (deploy) / P1 (usage)
Backend	APScheduler	Timeouts + consolidation windows	P1
Backend	PyJWT	JWT signing para approval tokens	P1
Backend	Pydantic v2	argos_contracts (cross-team interfaces)	P1 (shipped)
LLM	OpenAI GPT-4o-mini	Primary backend (cloud, US- based)	P1
LLM	Llama 3.1 8B vía Ollama	Fallback (local, zero-egress)	P1
LLM	BGE-large embeddings	Retrieval en RAG	P1
Notifications	python-telegram-bot	Telegram bot con inline buttons	P1
Notifications	discord-webhook	Discord notifications con role mention	P1
Notifications	twilio	Voice DTMF escalación	P1
UI	Streamlit 1.30+		

Categoría	Componente	Función	Owner principal
		Analyst Console + Approval Console	P4 (base) / P1 (Approval)
UI	OpenSearch Dashboards	MITRE heatmap, TTD histogram, layer perf	P4
Infra	Vagrant 2.4+	Provisioning de 3 VMs	P4
Infra	VirtualBox 7.x	Hypervisor para lab local	P4
Testing	pytest + respx + fakeredis	Tests cross-module	Todos
DB	PostgreSQL 15	Activo defendido	P4 (deploy + datos sintéticos)

9. Convenciones del repo

Git workflow

- **Branch principal:** `main`, protegida en GitHub.
- **Feature branches:** `feature/<persona>/<descripcion-corta>` — ejemplo: `feature/p2/isolation-forest-baseline`.
- **Commits convencionales:** `feat:`, `fix:`, `docs:`, `test:`, `refactor:`, `chore:`.
- **PRs requieren:** CI verde + 1 review. Pairing: P1↔P2, P3↔P4.
- **Push diario obligatorio** antes de las 22:00 durante el sprint.

Estructura del repo (post ADR-0008)

```

argos/
├── README.md           # Entry point del proyecto
├── LICENSE             # MIT
├── pyproject.toml      # Metadata + extras por módulo
├── .env.example        # Plantilla de variables (REAL .env va en .gitignore)
├── argos_contracts/   # □ Pydantic v2 cross-team (entregado · v1.1.0 · 69 tests)
│   ├── _mitre_data.py # MITRE_WHITELIST curado
│   ├── alert.py       # WazuhAlert, NormalizedAlert
│   ├── ml_score.py    # MLScore (P2)
│   ├── triage.py      # AlertContext, TriageResponse (P1)
│   ├── incident.py    # Incident state machine (P1)
│   ├── approval.py    # ApprovalRequest, ApprovalResponse (P1)
│   ├── enums.py       # Tier, Severity, NotificationChannelType, ...
│   └── tests/         # 69 validation tests
├── llm_triage/        # P1 – Capa 4 LLM Triage
│   ├── api/main.py    # FastAPI /triage endpoint
│   ├── llm_client/    # OpenAI primary + Llama local fallback
│   ├── rag/           # BM25 + BGE-large + RRF
│   └── prompts/       # Jinja2 templates
├── soar/              # P1 – SOAR Decision Engine + Approval API
│   ├── decision_engine/ # tier_classifier, state_machine, orchestrator
│   ├── approval/       # api, jwt_signer, consolidation
│   ├── notification/   # telegram, discord, twilio_voice, email
│   └── playbooks/      # host_isolation, process_kill, snapshot, throttle
├── ml/                # P2 – Capa 2 ML
│   ├── features/       # Feature extractors por dominio
│   ├── models/         # ransomware_ensemble, network_traffic, query_pattern
│   └── consumer/       # Redis stream consumer
├── detection/         # P3 – Capa 1 Sigma rules
│   ├── sigma-rules/
│   │   ├── ransomware/ # T1486, T1490, T1083, T1562
│   │   ├── network/    # T1498, T1499 rate-based
│   │   ├── database/   # query patterns
│   │   └── webapp/     # T1190 SQLi signatures
│   └── wazuh-rules/    # Convertidas con sigma-cli
├── deception/         # P3 – Capa 3 Canary
│   ├── canary_generator.py # Genera canary files
│   └── fim-configs/      # Wazuh FIM rules
├── ui/                # P4 (base) + P1 (Approval Console)
│   ├── streamlit_app/
│   │   ├── pages/
│   │   │   ├── 01_alert_inspection.py
│   │   │   ├── 02_approval_console.py # P1 - PIEZA CLAVE DEL DEMO
│   │   │   └── 03_audit_forensics.py
│   └── opensearch-dashboards/ # JSON dashboards exportados
├── attack-simulation/ # Simuladores multi-vector
│   ├── ransomware_simulator/ # P1 (LockBit-like, canary, novel)
│   ├── network_attacks/     # P4 (hping3, slowhttptest)
│   ├── webapp_attacks/      # P4 (sqlmap)
│   └── pg_simulator/        # P4 (SELECT masivo para UC-07)
├── lab/                # P4 – Vagrant + Terraform
│   ├── Vagrantfile
│   ├── provision/       # Scripts bash/PowerShell
│   └── inventory.yaml
├── evaluation/         # P2 + P4 – Métricas, datasets, reportes
├── docs/
│   ├── PROJECT_BRIEF.md # 90-second overview
│   ├── CONTEXT.md       # Onboarding completo
│   ├── PROJECT_STATUS.md # Honest snapshot
│   ├── EVALUATION_CRITERIA.md # Rúbrica del curso
│   ├── data-handling.md # T-030 sanitization policy
│   └── README.md        # Mapa de docs

```

```

├── architecture/      # SAD, threat model, flow diagrams
├── decisions/         # 8 ADRs + OPEN_QUESTIONS
├── use-cases/         # 8 UCs detallados
└── team/             # Sprint manuals (este documento + 4 individuales)

```

Variables de entorno (.env)

El `.env.example` documenta TODAS las variables. Las críticas para tu rol están en tu manual individual. Reglas globales:

- **NUNCA** commitear el `.env` — está en `.gitignore`.
- Cada integrante genera su propio `.env` partir del `.env.example`.
- Las credenciales compartidas (Telegram bot token, Discord webhook URL, OpenAI API key) las distribuye P1 vía canal privado (no en GitHub, no en Discord público).
- El `JWT_SECRET` se genera localmente con `openssl rand -hex 32`.

Convención de incident IDs

`INC-YYYY-MM-DD-NNN` donde `NNN` es contador diario zero-padded a 3 dígitos. Ejemplo: `INC-2026-05-26-001`. El contador se persiste en Redis con TTL diario.

10. Quick start del entorno común

Estos pasos son comunes a TODOS los integrantes antes de empezar el sprint. Tu manual individual asume que esto está hecho.

Paso 1 — Clonar repo

```

cd ~/projects                # o donde guardes proyectos
git clone https://github.com/EnzoOrdonez/argos.git
cd argos

```

Paso 2 — Crear virtualenv Python

```

python3 -m venv .env
source .env/bin/activate      # Linux/macOS
# .env\Scripts\activate       # Windows PowerShell
pip install -U pip setuptools wheel

```

Paso 3 — Instalar dependencias core + tu rol

```

# Todos instalan estos:
pip install -e ".[dev]"

# Además según tu rol:
pip install -e ".[contracts]"    # P1 (siempre + más abajo)
pip install -e ".[ml]"           # P2
pip install -e ".[soar,llm]"     # P1 (servicios)
pip install -e ".[ui]"           # P4

```

Paso 4 — Verificar contracts

```
pytest argos_contracts/tests/ -v
# Esperado: 69 passed
```

Si no pasan los 69 tests, revisa que el venv esté activado (`which python` debe apuntar a `.venv/bin/python`).

Paso 5 — Copiar plantilla de variables

```
cp .env.example .env
# Editar .env con tus valores reales (tu manual individual te dice cuáles)
```

Paso 6 — Configurar git

```
git config user.name "<Tu Nombre>"
git config user.email "<tu@email.com>"
# Crear tu branch:
git checkout -b feature/<tu-pX>/sprint-w1-init
```

11. Comunicación del equipo durante el sprint

Standup diario

- **Hora:** 9:00 AM
- **Canal:** Discord `#argos-standup` , llamada de voz
- **Duración:** 20 minutos (cada integrante ~3-4 min)
- **Formato (per `docs/team/standup-template.md`):**
 - Lo que cerré ayer (PRs mergeados, tests passing)
 - Lo que cierro hoy (objetivos del día)
 - Bloqueos (qué necesito de otro integrante)

Canales Discord del equipo

- `#argos-standup` — standup diario
- `#argos-help` — preguntas técnicas urgentes
- `#argos-prs` — notificación de PRs abiertos (GitHub bot)
- `#argos-incidents` — donde el bot ARGOS enviará notificaciones del demo

Reglas operativas (post ADR-0008)

1. **No tocar la doc esta semana.** Los docs están sincronizados con la realidad. Si descubres algo arquitectónico nuevo, abre un ADR-0009 en lugar de modificar SAD/threat model/README.
2. **No optimizar prematuramente.** El objetivo es que los 8 UCs corran end-to-end, no que sean óptimos. Performance fine-tuning en semana 2.

3. **Mocks son OK al inicio.** Si tu pieza depende de otra que aún no está lista, usa FakeRedis, mocked HTTP, o synthetic data. Integración real cuando ambas piezas estén listas.
4. **Verificar en lab real al menos 2 veces al día.** Cada integrante corre el flow E2E en su Vagrant antes del almuerzo y antes de pushear.
5. **Pedir ayuda en menos de 30 minutos.** Si llevas más de media hora atascado, pingueas en `#argos-help` o llamas a otro integrante. No debug solitario.
6. **Push diario obligatorio** antes de las 22:00. Si no pusheas, tu nombre aparece en el standup del día siguiente.

Claude Code / asistentes IA — política reinterpretada (ADR-0008)

Cada integrante puede usar Claude Code (o cualquier asistente IA: Cursor, GitHub Copilot, ChatGPT) como **acelerador en SU propia parte**. La condición no-negociable: cada integrante DEBE entender el código que produce con asistencia de IA y poder defenderlo en viva sin la asistencia presente. La asistencia es para velocidad, NO para reemplazar comprensión.

La regla específica que se mantiene: P1 (Enzo) no escribe código de otros integrantes con Claude Code. P1 puede asesorar y revisar, no producir el código de otros.

12. Lo que NO se entrega en esta semana 1

Para que no te sorprendas cuando llegue Día 7 sin estas cosas:

- **Calibración Q5 protocol** con dataset etiquetado real (~100 ransomware + ~500 benignas). Semana 2.
- **UC-03 split-brain con 4 aprobadores reales** no scripted. Semana 2-3.
- **UC-05 stealth attack** end-to-end pulido. Semana 2.
- **PRs Sigma upstream aceptados** por SigmaHQ maintainers (depende de tiempos externos). Semana 2-3.
- **Video demo final editado.** Semana 3.
- **Informe técnico final.** Semana 3.
- **Cross-encoder reranker en RAG** (descartado del scope v1 per ADR-0001 v2).

Lo que SÍ se completa al cierre del sprint Día 7: 5 UCs corriendo end-to-end (UC-01, UC-02, UC-04, UC-06, UC-07), con UC-08 como nice-to-have, con dos rehearsals al domingo.

13. Documentos relacionados (referencia completa)

Si algo de este documento no quedó claro o necesitas más profundidad:

Si quieres saber...	Lee
Arquitectura completa de cada bloque	docs/architecture/SOLUTION_ARCHITECTURE_DOCUMENT.md
Por qué se tomó cada decisión arquitectónica	docs/decisions/ (ADRs 0001-0008)
Análisis de amenazas STRIDE/FMEA	docs/architecture/THREAT_MODEL.md
Detalle de los 8 UCs	docs/use-cases/USE_CASES.md
Política de manejo de datos sensibles a LLM	docs/data-handling.md
Rúbrica del curso y mapping a deliverables	docs/EVALUATION_CRITERIA.md
Estado real vs. documentado del proyecto	docs/PROJECT_STATUS.md
Flujo del sistema visualmente	docs/architecture/argos_flow.html
Tu manual de sprint individual	docs/team/sprint-week-1-p<X>-<nombre>.md
Plan operacional general del sprint	docs/team/sprint-week-1-overview.md

Change log

Versión	Fecha	Cambio	Autor
1.0	2026-05-24	Initial — sección común de introducción para los 4 manuales individuales. Cubre arquitectura, UCs, ejemplo end-to-end UC-01, glosario MITRE, stack tecnológico, convenciones del repo, política Claude Code, quick start.	P1 (Enzo Ordoñez Flores)

Parte II — Manual individual de Angeles Castillo

Sprint Semana 1 — Manual de P3 (Angeles Castillo)

Field	Value
Owner	Angeles Castillo
Rol	P3 · Detection Engineer + Deception
Goal de la semana	Capa 1 (Sigma rules para ransomware + network + database + webapp) + Capa 3 (canary generator + FIM whodata) + validación con Atomic Red Team y Caldera + 2-4 PRs Sigma upstream a SigmaHQ
Effort estimado	6 horas/día × 7 días = 42 horas
Pre-requisitos	Leer docs/team/sprint-week-1-common-intro.md y docs/decisions/0008-multi-vector-scope-expansion.md

Antes de empezar — prerequisites

Hardware

- Laptop con **8 GB RAM mínimo** (no necesitas correr VMs locales — usas el lab de P4 o sintéticos).
- 20 GB disco libre.
- macOS / Linux / Windows.

Software base

```
python3 --version    # 3.11+
git --version
# Editor: VSCode con extensiones YAML, Sigma syntax highlight (Microsoft Sentinel pack)
```

Cuentas externas

- **GitHub** con fork de SigmaHQ/sigma (para PRs upstream).
- Acceso al repo Enzo0rdonez/argos con permiso de PR.

Día 1 (Lunes) — Setup sigma-cli + Atomic Red Team

Goal: entorno listo, primera regla Sigma para `vssadmin delete shadows` escrita, convertida a Wazuh y validada localmente.

Tiempo: 5 horas.

Paso 1.1 — Clonar repo y crear venv (15 min)

```
cd ~/projects
git clone https://github.com/Enzo0rdonez/argos.git
cd argos

python3 -m venv .venv
source .venv/bin/activate
pip install -U pip setuptools wheel
pip install -e ".[dev]"
pip install sigma-cli pysigma-backend-wazuh
```

Verificación:

```
sigma --help
# debe mostrar comandos: convert, check, list
sigma list backends | grep wazuh
# debe mostrar wazuh backend disponible
```

Paso 1.2 — Crear estructura del módulo detection/ (10 min)

```
mkdir -p detection/sigma-rules/{ransomware,network,database,webapp}
mkdir -p detection/wazuh-rules detection/tests
touch detection/__init__.py
mkdir -p deception/canary_generator deception/fim-configs
```

Paso 1.3 — Fork de SigmaHQ y clonar Atomic Red Team (30 min)

```
# Ve a github.com/SigmaHQ/sigma, haz Fork a tu usuario
# Clónalo en otro directorio:
cd ~/projects
git clone https://github.com/<tu-usuario>/sigma.git sigmahq-fork
cd sigmahq-fork
git remote add upstream https://github.com/SigmaHQ/sigma.git

# Clonar Atomic Red Team (para validar reglas)
cd ~/projects
git clone https://github.com/redcanaryco/atomic-red-team.git
```

Paso 1.4 — Primera regla Sigma: T1490 vssadmin (1.5 h)

Crea `detection/sigma-rules/ransomware/T1490_vssadmin_delete_shadows.yml`:

```

title: Volume Shadow Copies Deletion (vssadmin)
id: 4a9b1c2d-5e6f-7890-abcd-ef0123456789
status: experimental
description: |
  Detects vssadmin.exe being used to delete Volume Shadow Copies,
  a common ransomware pre-encryption step (T1490 Inhibit System Recovery).
references:
  - https://attack.mitre.org/techniques/T1490/
  - https://www.bleepingcomputer.com/news/security/lockbit-ransomware-deletes-shadow-copies/
author: Angeles Castillo (ARGOS P3)
date: 2026-05-24
tags:
  - attack.impact
  - attack.t1490
  - argos.ransomware
logsource:
  product: windows
  category: process_creation
detection:
  selection:
    Image|endswith: '\vssadmin.exe'
    CommandLine|contains|all:
      - 'delete'
      - 'shadows'
  condition: selection
falsepositives:
  - Legitimate backup software using vssadmin (rare in production)
level: high

```

Validar con sigma-cli:

```

sigma check detection/sigma-rules/ransomware/T1490_vssadmin_delete_shadows.yml
# Esperado: [ ] valid Sigma rule

```

Convertir a Wazuh:

```

sigma convert -t wazuh -f xml \
  detection/sigma-rules/ransomware/T1490_vssadmin_delete_shadows.yml \
  -o detection/wazuh-rules/T1490_vssadmin_delete_shadows.xml
cat detection/wazuh-rules/T1490_vssadmin_delete_shadows.xml

```

Paso 1.5 — Validar con Atomic Red Team (1 h)

Cada regla Sigma debe parearse con un Atomic test que la dispare. Para T1490:

```

# Buscar atomic tests para T1490
grep -l "T1490" ~/projects/atomic-red-team/atomics/T1490/*
# Esperado: vssadmin delete shadows test exists

# Para correr este atomic test necesitarás coordinar con P4 que tenga la Windows VM
# Por ahora documenta el atomic test en detection/tests/atomic_pairings.md

```

Crea `detection/tests/atomic_pairings.md`:

```

# Sigma rules ↔ Atomic Red Team pairings

| Sigma rule | Atomic test | Status |
|-----|-----|-----|
| T1490_vssadmin_delete_shadows.yml | `T1490/Atomic Test #1` | Pending: needs Windows VM (P4) |

```

Paso 1.6 — Commit + PR (10 min)

```
git checkout -b feature/p3/sigma-ransomware-batch1
git add detection/
git commit -m "feat(p3): primera regla Sigma T1490 vssadmin + wazuh conversion"
git push origin feature/p3/sigma-ransomware-batch1
```

Verificación EOD Día 1

- ☐ `sigma --help` funciona
- ☐ 1 regla Sigma valid + convertida a Wazuh
- ☐ PR abierto

Día 2 (Martes) — 4 reglas más de ransomware

Goal: 5 reglas Sigma core para ransomware mapeadas a las técnicas MITRE T1486, T1083, T1562.001, T1021, T1071.

Tiempo: 6 horas.

Paso 2.1 — T1486 Mass file encryption (1 h)

detection/sigma-rules/ransomware/T1486_mass_file_encryption_extension.yml :

```
title: Mass File Renames to Ransomware Extension
id: <generate uuid4>
status: experimental
description: |
  Detects mass file rename operations to known ransomware extensions
  (.locked, .crypt, .enc, .lockbit, etc.) within a short time window.
references:
  - https://attack.mitre.org/techniques/T1486/
author: Angeles Castillo
date: 2026-05-24
tags:
  - attack.impact
  - attack.t1486
logsource:
  product: windows
  category: file_event
detection:
  selection:
    EventID: 11 # Sysmon FileCreate
    TargetFilename|endswith:
      - '.locked'
      - '.lockbit'
      - '.crypt'
      - '.enc'
      - '.aes'
      - '.ryk'
  timeframe: 60s
  condition: selection | count() > 20
level: critical
```

Paso 2.2 — T1083 File enumeration burst (1 h)

```

title: Suspicious File Enumeration Burst
description: Process enumerating >1000 files in user directory in <30s
detection:
  selection:
    EventID: 11
    TargetFilename|contains: '\Documents\'
  timeframe: 30s
  condition: selection | count() by Image > 1000
level: medium

```

Paso 2.3 — T1562.001 Disable Defender (45 min)

```

title: Windows Defender Disabled
detection:
  selection:
    Image|endswith:
      - '\powershell.exe'
      - '\cmd.exe'
    CommandLine|contains|all:
      - 'Set-MpPreference'
      - '-DisableRealtimeMonitoring'
      - '$true'
  condition: selection
level: high

```

Paso 2.4 — T1021 SMB lateral movement (45 min)

```

title: SMB Lateral Movement Indicator
detection:
  selection:
    EventID: 3
    DestinationPort: 445
    DestinationIp|cidr: '10.0.0.0/24'
  condition: selection | count() by SourceIp > 5
timeframe: 60s
level: medium

```

Paso 2.5 — T1071 Beacon C2 (45 min)

```

title: Suspicious Outbound HTTP Beacon Pattern
detection:
  selection:
    EventID: 3
    Initiated: true
    DestinationPort: 443
  filter:
    Image|endswith:
      - '\chrome.exe'
      - '\firefox.exe'
      - '\edge.exe'
  condition: selection and not filter | count() by Image > 30
timeframe: 5min
level: low

```

Paso 2.6 — Convertir todas a Wazuh + tests (1 h)

```
for f in detection/sigma-rules/ransomware/*.yml; do
  name=$(basename "$f" .yml)
  sigma convert -t wazuh -f xml "$f" -o "detection/wazuh-rules/$name.xml"
done
ls detection/wazuh-rules/
# Esperado: 5 archivos XML
```

Paso 2.7 — Commit (10 min)

```
git add detection/
git commit -m "feat(p3): 4 reglas Sigma más para ransomware kill chain"
git push
```

Verificación EOD Día 2

- ☐ 5 reglas Sigma totales, todas valid con `sigma check`
 - ☐ 5 archivos Wazuh XML en `detection/wazuh-rules/`
-

Día 3 (Miércoles) — Canary generator + FIM rules

Goal: Capa 3 deception completa: generador de canary files + reglas FIM whodata.

Tiempo: 6 horas.

Paso 3.1 — Canary generator Python (2 h)

`deception/canary_generator/generator.py` :

```

"""Genera canary files con contenido dummy realista en paths estratégicos."""
import os
import random
import string
from pathlib import Path
from datetime import datetime

CANARY_PROFILES = {
    "financials_Q4_2025.xlsx": {
        "size_kb": 24,
        "content_seed": "PK\x03\x04", # ZIP magic (xlsx is ZIP)
    },
    "passwords.txt": {
        "size_kb": 2,
        "content_seed": "alice@example.com:Admin1234\n",
    },
    "db_backup.sql": {
        "size_kb": 156,
        "content_seed": "-- PostgreSQL database dump\nSET statement_timeout = 0;\n",
    },
}

def generate_canary(path: Path, profile_name: str) -> None:
    profile = CANARY_PROFILES[profile_name]
    seed = profile["content_seed"].encode()
    target_size = profile["size_kb"] * 1024
    padding = target_size - len(seed)

    path.parent.mkdir(parents=True, exist_ok=True)
    with path.open("wb") as f:
        f.write(seed)
        f.write(b" " * padding)

    # Antedatar el mtime para que parezca un archivo viejo
    old_time = datetime(2024, 6, 15).timestamp()
    os.utime(path, (old_time, old_time))

def deploy_canaries(base_dir: Path) -> list[Path]:
    """Deploya los 3 canaries en sub-directorios estratégicos."""
    deployed = []
    for name in CANARY_PROFILES:
        target = base_dir / "Documents" / name
        generate_canary(target, name)
        deployed.append(target)
    return deployed

if __name__ == "__main__":
    import sys
    base = Path(sys.argv[1]) if len(sys.argv) > 1 else Path("/tmp/argos-canaries-test")
    deployed = deploy_canaries(base)
    for p in deployed:
        print(f"Deployed: {p} ({p.stat().st_size} bytes)")

```

Test:

```

python -m deception.canary_generator.generator /tmp/argos-canaries-test
ls -la /tmp/argos-canaries-test/Documents/

```

Paso 3.2 — FIM whodata config (1.5 h)

```
deception/fim-configs/wazuh-fim-canary-windows.xml :
```

```
<!-- Wazuh syscheck config for canary monitoring (Windows) -->
<syscheck>
  <directories check_all="yes" realtime="yes" whodata="yes" report_changes="yes">
    C:\Users\Demo\Documents\financials_Q4_2025.xlsx,
    C:\Users\Demo\Documents\passwords.txt,
    C:\Users\Demo\Documents\db_backup.sql
  </directories>
</syscheck>
```

deception/fim-configs/wazuh-fim-canary-linux.xml :

```
<syscheck>
  <directories check_all="yes" realtime="yes" whodata="yes" report_changes="yes">
    /var/backups/postgres/db_backup.sql,
    /home/argos-demo/Documents/financials_Q4_2025.xlsx,
    /home/argos-demo/Documents/passwords.txt
  </directories>
</syscheck>
```

Paso 3.3 — Wazuh custom rule canary fire (1 h)

detection/wazuh-rules/canary_access.xml :

```
<group name="argos,canary,">
  <rule id="100100" level="12">
    <if_sid>550,553,554</if_sid> <!-- syscheck-related Wazuh internal rules -->
    <match>db_backup.sql|passwords.txt|financials_Q4_2025.xlsx</match>
    <description>ARGOS canary file accessed – possible ransomware activity</description>
    <mitre>
      <id>T1486</id>
    </mitre>
  </rule>
</group>
```

Paso 3.4 — Commit (10 min)

```
git add deception/ detection/wazuh-rules/canary_access.xml
git commit -m "feat(p3): canary generator + FIM whodata + Wazuh custom rule"
git push
```

Verificación EOD Día 3

- ☐ `python -m deception.canary_generator.generator /tmp/test` crea 3 archivos
- ☐ FIM configs XML válidos
- ☐ Custom Wazuh rule sintácticamente correcta

Día 4 (Jueves) — Reglas network para UC-06 (DDoS)

Goal: Reglas Sigma rate-based para detectar DDoS volumetric.

Tiempo: 6 horas.

Paso 4.1 — Investigar rate rules nativas en Wazuh (1 h)

Lee la doc de Wazuh sobre `<frequency>X</frequency>` y `<timeframe>Y</timeframe>` que cuentan eventos en ventanas. Wazuh tiene rate rules nativas — no necesitas escribir Sigma para esto, escribir directamente Wazuh XML.

Paso 4.2 — Regla DDoS SYN flood (2 h)

detection/sigma-rules/network/T1498_syn_flood.yml :

```
title: TCP SYN Flood Detection
id: <uuid>
status: experimental
description: Detects excessive SYN packets to a single destination port (T1498 Direct Network Flood)
tags:
  - attack.impact
  - attack.t1498.001
logsource:
  product: linux
  service: iptables
detection:
  selection:
    log_msg|contains: 'TCP SYN'
  timeframe: 10s
  condition: selection | count() by DESTINATION_IP > 1000
level: critical
```

Más una rule Wazuh directa para HTTP flood:

detection/wazuh-rules/network_flood.xml :

```
<group name="argos,network,ddos,">
  <rule id="100200" level="10" frequency="500" timeframe="10">
    <if_matched_sid>31100</if_matched_sid> <!-- Wazuh's HTTP access rule -->
    <description>Possible HTTP flood: >500 requests in 10s from same IP</description>
    <mitre>
      <id>T1498</id>
    </mitre>
  </rule>
</group>
```

Paso 4.3 — Validar con hping3 (coordinar con P4) (1 h)

P4 lanza desde otra máquina:

```
sudo hping3 --flood --syn -p 80 <linux-vm-ip>
```

Verificar que Wazuh dispara rule 100200 dentro de 10 segundos.

Paso 4.4 — Commit (10 min)

```
git add detection/sigma-rules/network/ detection/wazuh-rules/network_flood.xml
git commit -m "feat(p3): regla DDoS SYN flood + HTTP flood rate-based"
git push
```

Verificación EOD Día 4

- ☐ 2 reglas network creadas
- ☐ Rule Wazuh dispara con hping3 flood

Día 5 (Viernes) — Reglas database + webapp (UC-07, UC-08)

Goal: Reglas para query patterns sospechosos (UC-07) y SQL injection patterns (UC-08).

Tiempo: 6 horas.

Paso 5.1 — Regla query masivo (UC-07) (2 h)

detection/sigma-rules/database/anomalous_query_pattern.yml :

```
title: Anomalous Database Query Pattern
id: <uuid>
description: |
  Detects large SELECT queries (>10K rows returned, >5s duration)
  outside business hours. Possible exfiltration or legitimate FP.
tags:
  - attack.collection
  - attack.t1078
logsource:
  product: postgresql
  service: pgaudit
detection:
  selection:
    log_type: 'READ'
    statement|contains: 'SELECT'
    rows_returned: '>10000'
  timefilter:
    hour: '<6 OR >22' # fuera de horario laboral 6 AM - 10 PM
    condition: selection AND timefilter
level: medium
```

Paso 5.2 — Reglas SQL injection (UC-08) (3 h)

detection/sigma-rules/webapp/T1190_sql_injection_patterns.yml :

```

title: SQL Injection Patterns in HTTP Requests
id: <uuid>
description: Detects common SQL injection signatures in HTTP query parameters
tags:
  - attack.initial_access
  - attack.t1190.001
logsource:
  category: webserver
  product: nginx
detection:
  selection_keywords:
    request|contains|any:
      - "' OR '1'='1"
      - "' OR 1=1--"
      - "UNION SELECT"
      - "' UNION SELECT NULL"
      - "'; DROP TABLE"
      - "WAITFOR DELAY"
      - "SLEEP("
      - "INFORMATION_SCHEMA"
  condition: selection_keywords
level: high

```

Paso 5.3 — Validar con sqlmap (coordinar con P4) (1 h)

P4 ejecuta:

```
sqlmap -u "http://<webapp>/?id=1" --batch --dbs --threads=5
```

Verificar que dispara la regla.

Paso 5.4 — Commit (10 min)

Verificación EOD Día 5

- ☐ 2 reglas database/webapp creadas
- ☐ sqlmap dispara la regla SQLi

Día 6 (Sábado) — PRs upstream a SigmaHQ

Goal: Abrir 2-4 PRs en [SigmaHQ/sigma](#) con las reglas más generalizables.

Tiempo: 6 horas.

Paso 6.1 — Identificar reglas upstream-worthy (1 h)

Las reglas más generalizables (no específicas a ARGOS):

- T1490 vssadmin delete shadows (clásica, puede tener una en SigmaHQ ya — verificar)
- T1486 mass file rename to ransomware extension
- T1562.001 Defender disabled via PowerShell

Paso 6.2 — Adaptar a estándares SigmaHQ (2 h)

Cada regla debe tener:

- UUID único
- `references` con URLs públicos
- `author` con tu nombre
- `falsepositives` exhaustivo
- Sin tags `argos.*` (eliminar tags privados)

Paso 6.3 — Abrir PRs (2 h)

En tu fork SigmaHQ:

```
cd ~/projects/sigmahq-fork
git checkout -b argos/T1490-vssadmin-delete-shadows
cp ../argos/detection/sigma-rules/ransomware/T1490_vssadmin_delete_shadows.yml rules/windows/process_creation/proc_cr
# Editar para quitar tags argos.* y ajustar al estilo SigmaHQ
git commit -m "rules(windows): add vssadmin delete shadows detection"
git push origin argos/T1490-vssadmin-delete-shadows
# Abrir PR en github.com/SigmaHQ/sigma
```

Paso 6.4 — Documentar PRs (30 min)

`detection/tests/upstream_prs.md`:

```
# SigmaHQ upstream PR tracker

| PR # | Rule | Status | Reviewer feedback |
|-----|-----|-----|-----|
| SigmaHQ/sigma#XXXX | T1490 vssadmin delete shadows | Open | Pending |
| SigmaHQ/sigma#YYYY | T1486 mass file rename | Open | Pending |
```

Verificación EOD Día 6

- ☐ 2-4 PRs abiertos en SigmaHQ
- ☐ Tracker documentado

Día 7 (Domingo) — Rehearsals + iteración

Mañana: Rehearsals con P4 ejecutando los 5 simuladores. Verificar cada regla dispara correctamente.

Tarde: Bug fixing — reglas que no disparan, falsos positivos descubiertos en baseline benigno.

Noche: Status update.

Entregable EOD Día 7

- ☐ ~10 reglas Sigma totales (5 ransomware + 2 network + 1 database + 2 webapp)
- ☐ 2-4 PRs upstream abiertos
- ☐ FIM whodata configurado y disparando

Apéndice A — Comandos diarios

```
# Activar env
cd ~/projects/argos && source .venv/bin/activate

# Validar todas las reglas Sigma
for f in detection/sigma-rules/**/*.yaml; do
    sigma check "$f"
done

# Convertir todas a Wazuh
for f in detection/sigma-rules/**/*.yaml; do
    out="detection/wazuh-rules/$(basename "$f" .yaml).xml"
    sigma convert -t wazuh -f xml "$f" -o "$out"
done

# Validar XML Wazuh
xmllint --noout detection/wazuh-rules/*.xml && echo "All Wazuh XML valid"

# Listar Atomic tests por técnica
ls ~/projects/atomic-red-team/atomics/ | head -20
```

Apéndice B — Troubleshooting

Síntoma	Causa	Fix
<code>sigma: command not found</code>	venv no activado	<code>source .venv/bin/activate</code>
<code>sigma check</code> fail	YAML mal formado	<code>python -c "import yaml; print(yaml.safe_load(open('rule.yaml')))"</code> para ver el error
Regla no dispara en Wazuh	Conversion sigma→wazuh perdió campos	Comparar el XML output con regla manual
FIM whodata no captura proceso	Sysmon no instalado correctamente	Coordinar con P4

Change log

Versión	Fecha	Cambio	Autor
1.0	2026-05-24	Initial manual P3 — 10 reglas Sigma (ransomware + network + database + webapp) + canary FIM + 2-4 PRs upstream.	P1